



*Earn cashback by sharing what you love.*

Product and architecture overview

1 · the business

2 · the product

3 · the architecture

backup · deep dives

by Dennis Potashnik

# Every everyday shopper becomes an affiliate — automatically

## THE GAP



### Shoppers

Shoppers share product links every day: "where did you get that?", but earn nothing for the purchases they drive.



### Cashback platforms

Existing platforms reward passive shopping through their own portal. The social recommendation goes unpaid and unmeasured.



### Organic word-of-mouth

Brands keep growing influencer budgets while organic word-of-mouth, which converts better — stays invisible.

## THE PRODUCT



**Wanthat turns the link you already send into a tracked affiliate link.**

Wanthat is the single registered affiliate across AliExpress / Shein / Amazon / others — when a friend buys, the commission flows in and is split between the recommender and the buyer.

**It monetizes a behavior that already exists.**

# Why Israel, why now

## 66%



of Israeli online orders are AliExpress — the MVP integration

## #1



WhatsApp penetration among the highest globally — group sharing is a daily habit

## \$17B+



global affiliate market — a proven commercial model

## 3 days



AliExpress attribution window — sharing must be instant

## 20+



payout via bank / card / Bit / PayBox

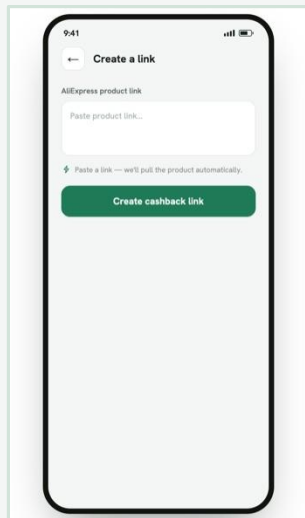
## Month 3



gates: 500 active sharers · >20% CTR · >6% conversion · >50% 30-day return

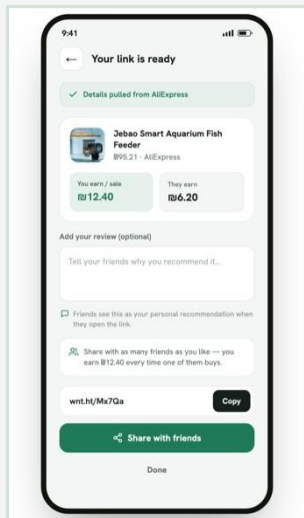
# How it works — share a recommendation

wanthat.app/create



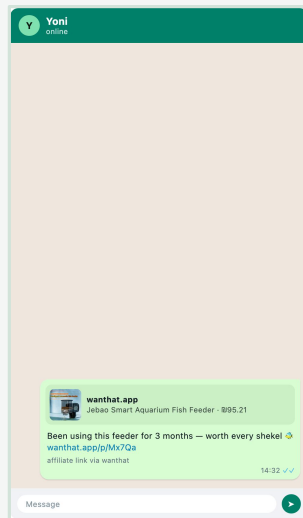
1 Member pastes a product link

wanthat.app/create



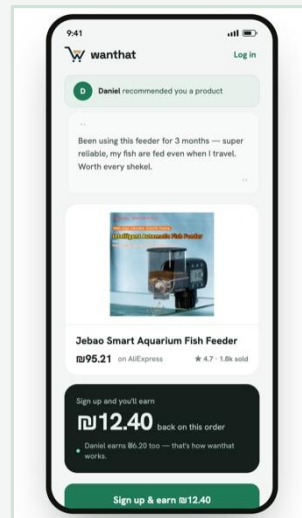
2 Link ready — cashback split shown

WhatsApp — off-platform



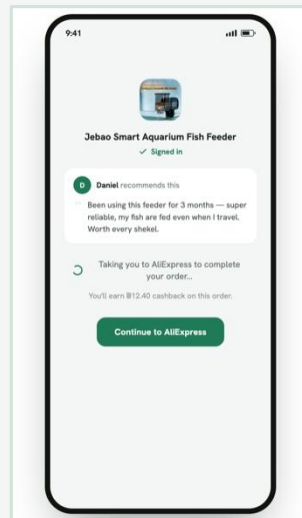
3 Shared — disclosure included

wanthat.app/p/Mx7Qa



4 Friend opens the branded landing

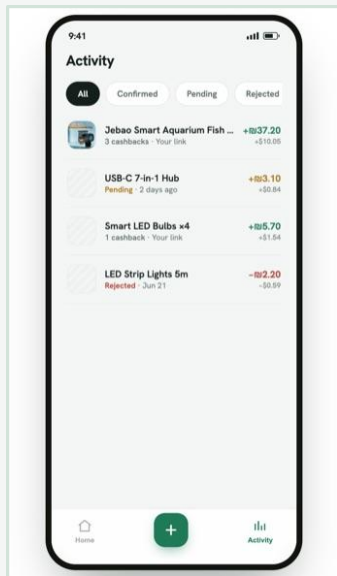
→ aliexpress.com



5 Sent to the store — attributed

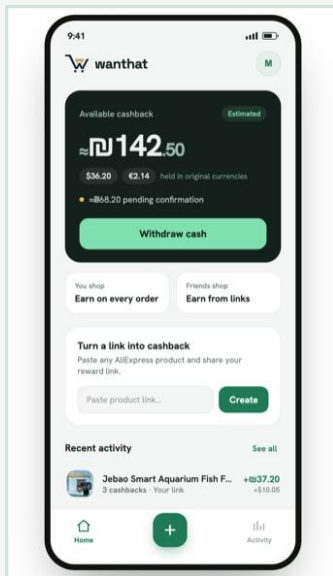
# How it works — the cashback comes back

wanthat.app/activity



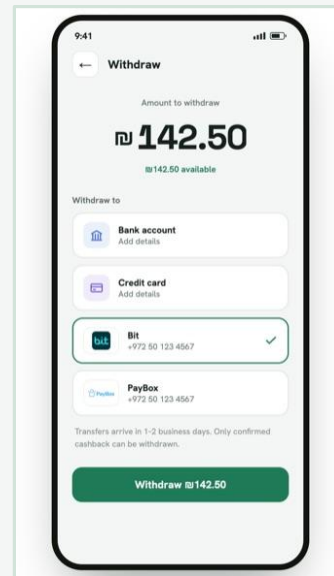
1 Conversion tracked — pending until the store confirms

wanthat.app/home



2 Wallet credited — estimated ILS over real currencies

wanthat.app/withdraw



3 Withdraw from ฿20 — bank, card, Bit or PayBox

# Engineering principles



## Optimize for cost

Avoid constant costs, zero interface endpoints, scale-to-zero, on-demand DBs.



## Zero to scale

A link going viral in a WhatsApp group is the potential spike.



## Security by design

The entire framework is about money movement. Apply least privilege access, MFA, data integrity provability, isolation of concerns, strict auditing and other security principles.



## Monorepo, schema-first

pnpm + Turborepo, TypeScript everywhere (Node 24, arm64).  
Zod contracts: inferred types + runtime validation at every boundary.



## Everything as code

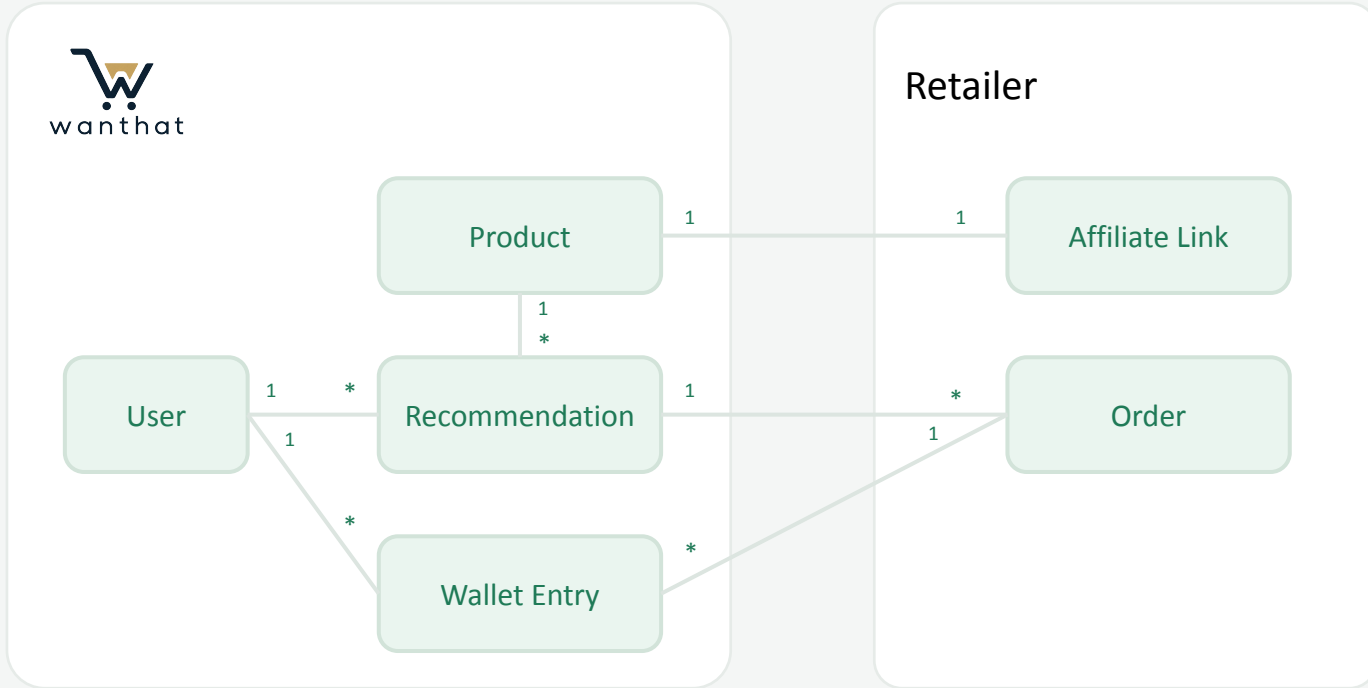
AWS CDK v2; per-env stacks; zero console changes.  
PRs run CI + cdk diff; merge deploys dev  
SQL migrations run in-deploy.  
Verify orphan resources after deployment.



## Decisions on record

ADRs beside the code. Locked.  
Change is a new superseding ADR, never an edit.

# Domain Object Model

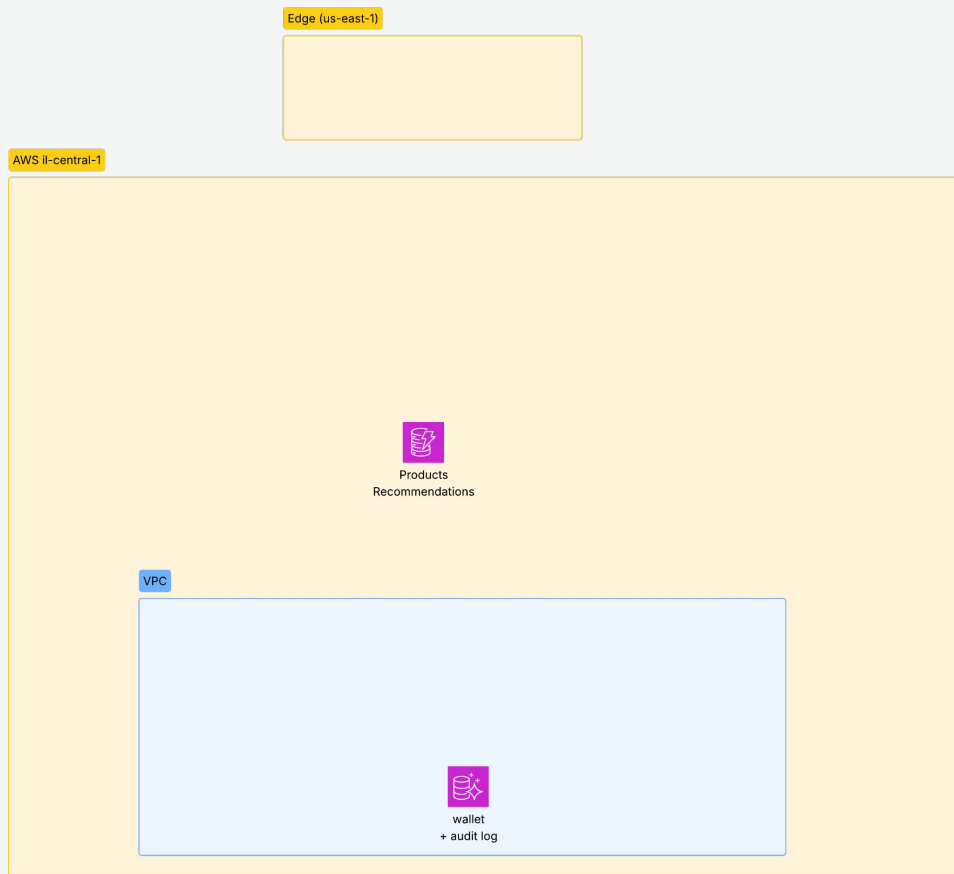


## Data stores and cost

| Data              | Decision                                              | Why                                                                                                            | Trade-off accepted                                                                                                                                                                                            |
|-------------------|-------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Money + Audit Log | Aurora Serverless v2<br>(0-2 ACU, IAM auth, no proxy) | ACID<br>Permissions enforced on DB level (GRANTs)<br>Storing audit log with hashed chains                      | Scale-to-zero cold resume ~20 s (60 s connect timeout + SPA warm-up probe); 50-connection cap.<br>Possible simple workaround - cached last known totals (display while reloading) per user on SPA or backend. |
| Customer PII      | Cognito user attributes are the system of record      | Auth path touches zero databases;<br>GDPR delete = one call;<br>The only backup carrying PII is cognito backup | ListUsers-only queries (no joins, one filter);<br>no PITR;<br>no attribute history.                                                                                                                           |
| Operational       | DynamoDB on-demand (9 tables)                         | Viral bursts absorbed at \$0 idle;<br>access patterns modeled as projections (byOwner, byState GSIs)           | No joins, no ad-hoc queries;<br>counters kept exact via same-table transactions                                                                                                                               |

**Deliberate constraint:** no cross-table transactions exist anywhere — counter rows live inside the counted table (single-table TransactWriteItems), ledger + audit are sequential idempotent appends behind a unique (order\_id, kind, status) index. Cross-store consistency is by keys and idempotency, not coordination.

# Architecture



Starting with:

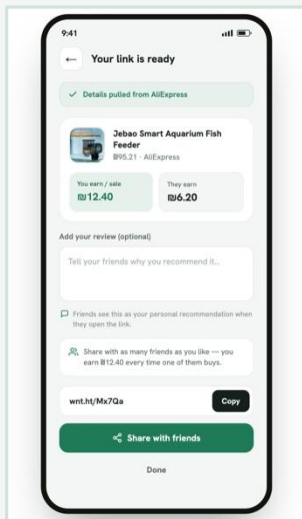
in-VPC Aurora Serverless v2

and

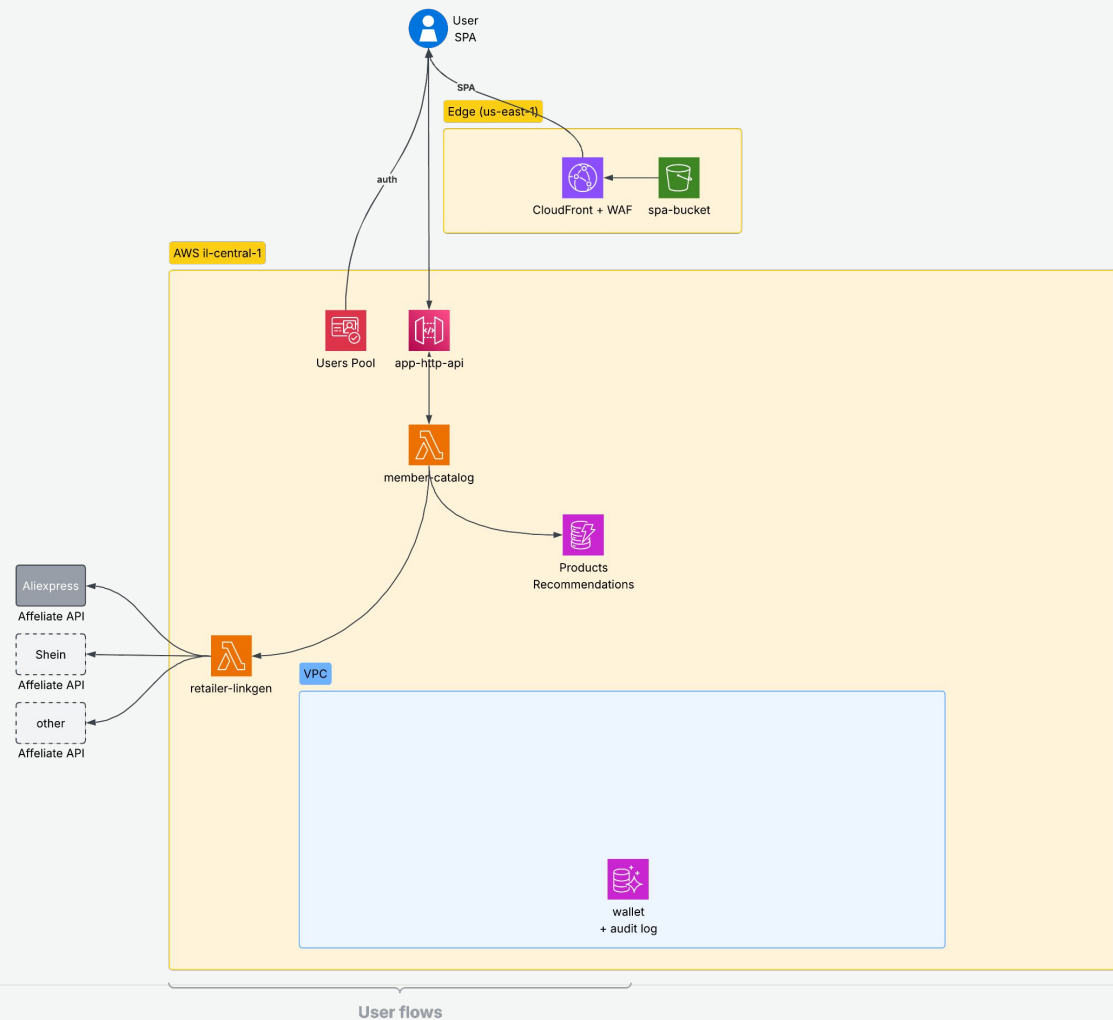
DynamoDB on-demand

# Architecture

**Usecase 1:** Logged in user generates a recommendation.

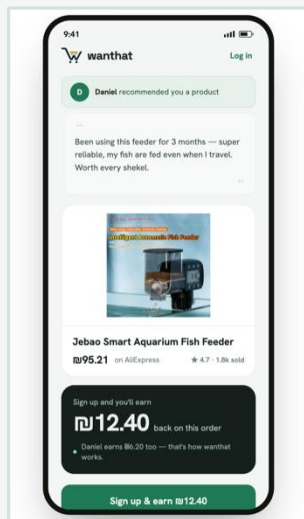


- SPA is served from S3 via CloudFront
- Cognito-native authentication on application level
- Retailer link is created once for a product

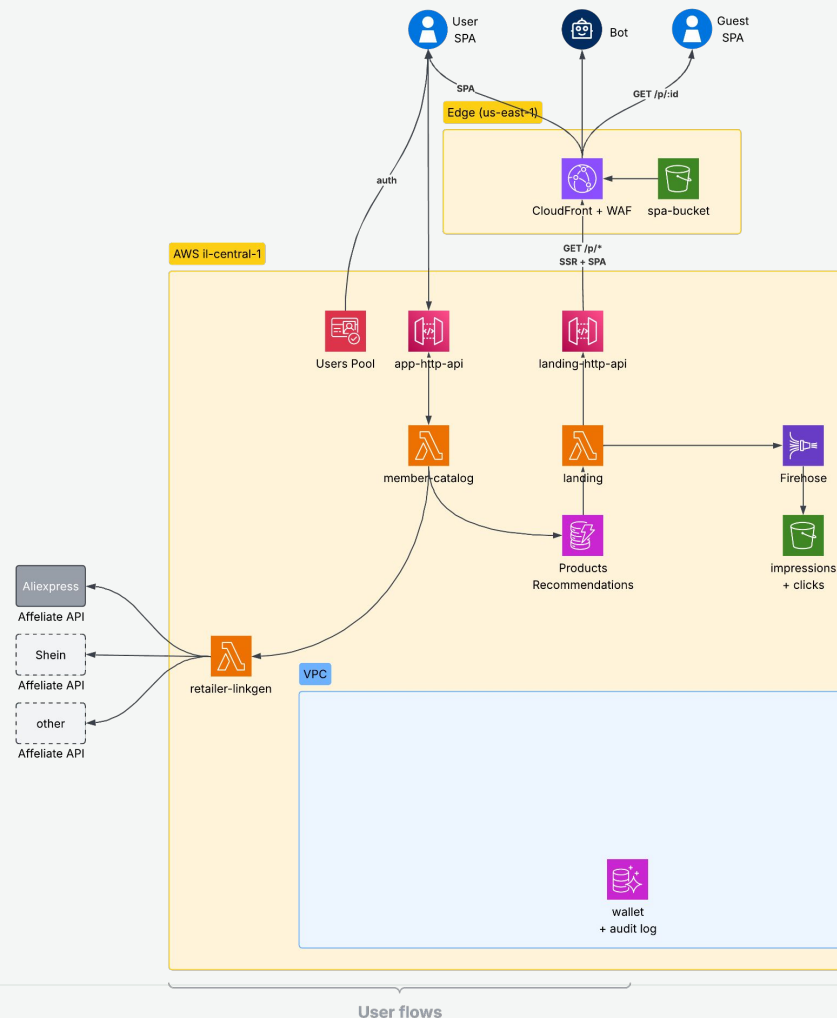


# Architecture

Usecase 2: Recommendation is shared

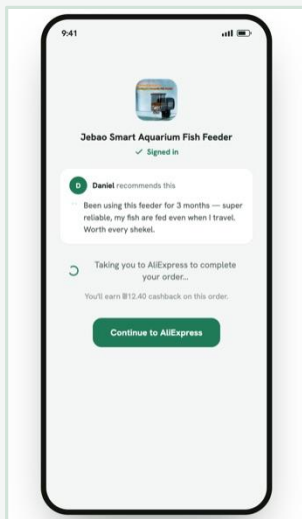


- This is the hot path
- Recommendation is server rendered and cached on CloudFront.
- TS app is added to the page for auth / registration and redirect link generation

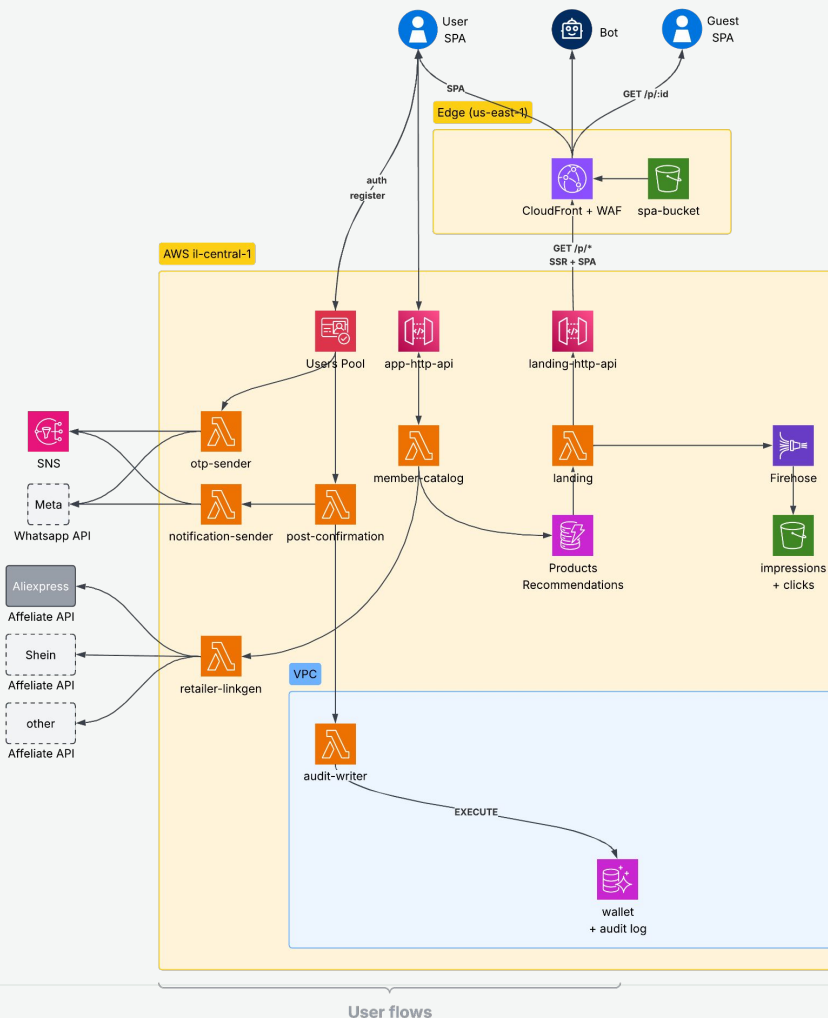


# Architecture

**Usecase 3:** User registration/login/guest and redirect to retailer.

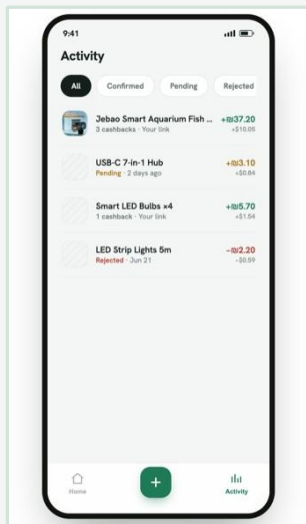


- Each row contains the hash of a previous Row in audit log.
- audit\_writer only granted to execute the procedure
- Stored procedure ensures proper locking In case of concurrency

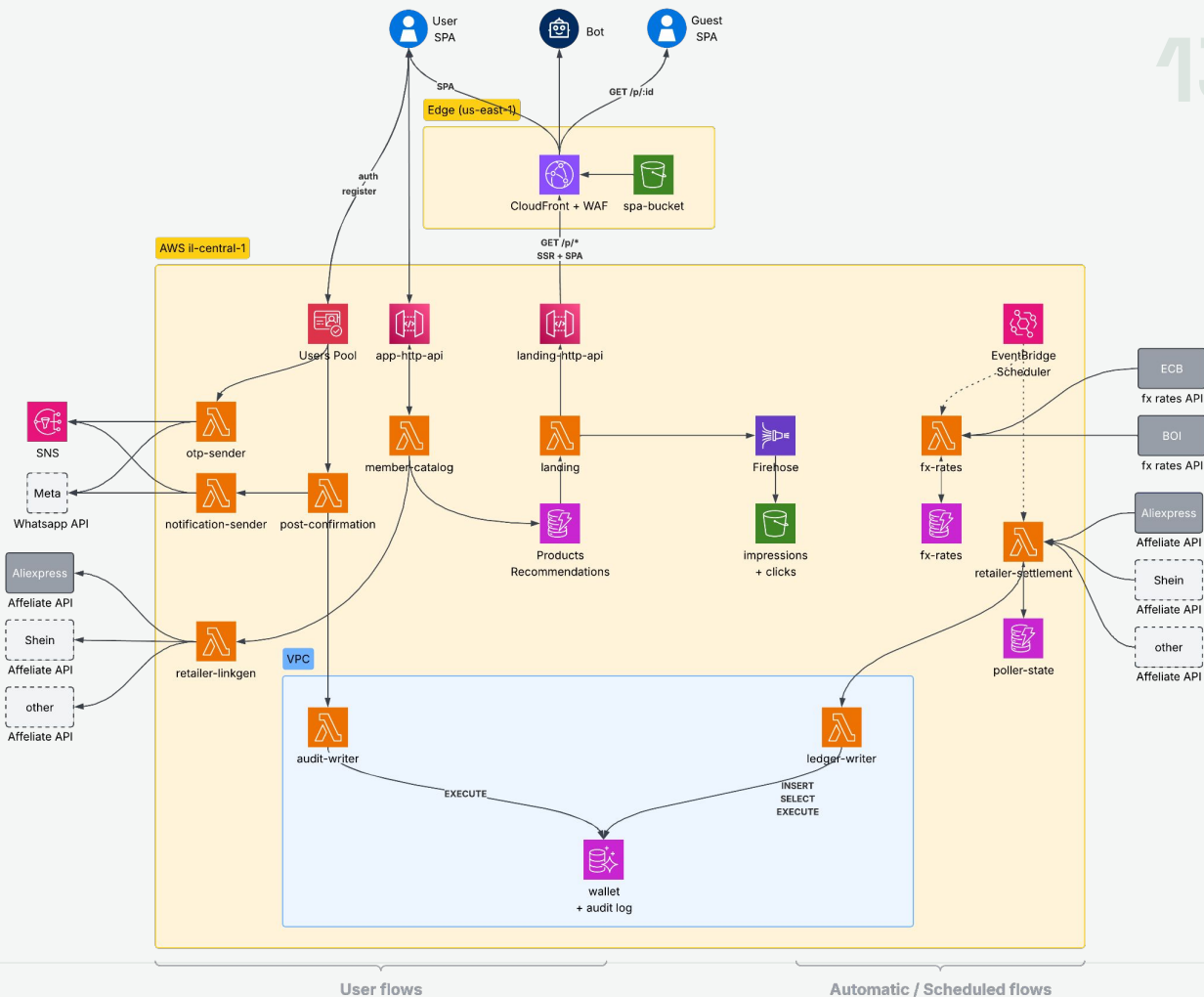


# Architecture

**Usecase 4:** Affiliation settlement pulled from the retailer in the background.

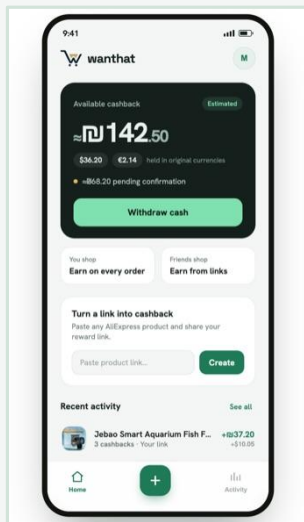


- The flow is internal. It is the only flow that can append wallet entries (GRANT level).
- Wallet entry is immutable.
- A side usecase is to pull exchange rates from foreign exchange rates provider.

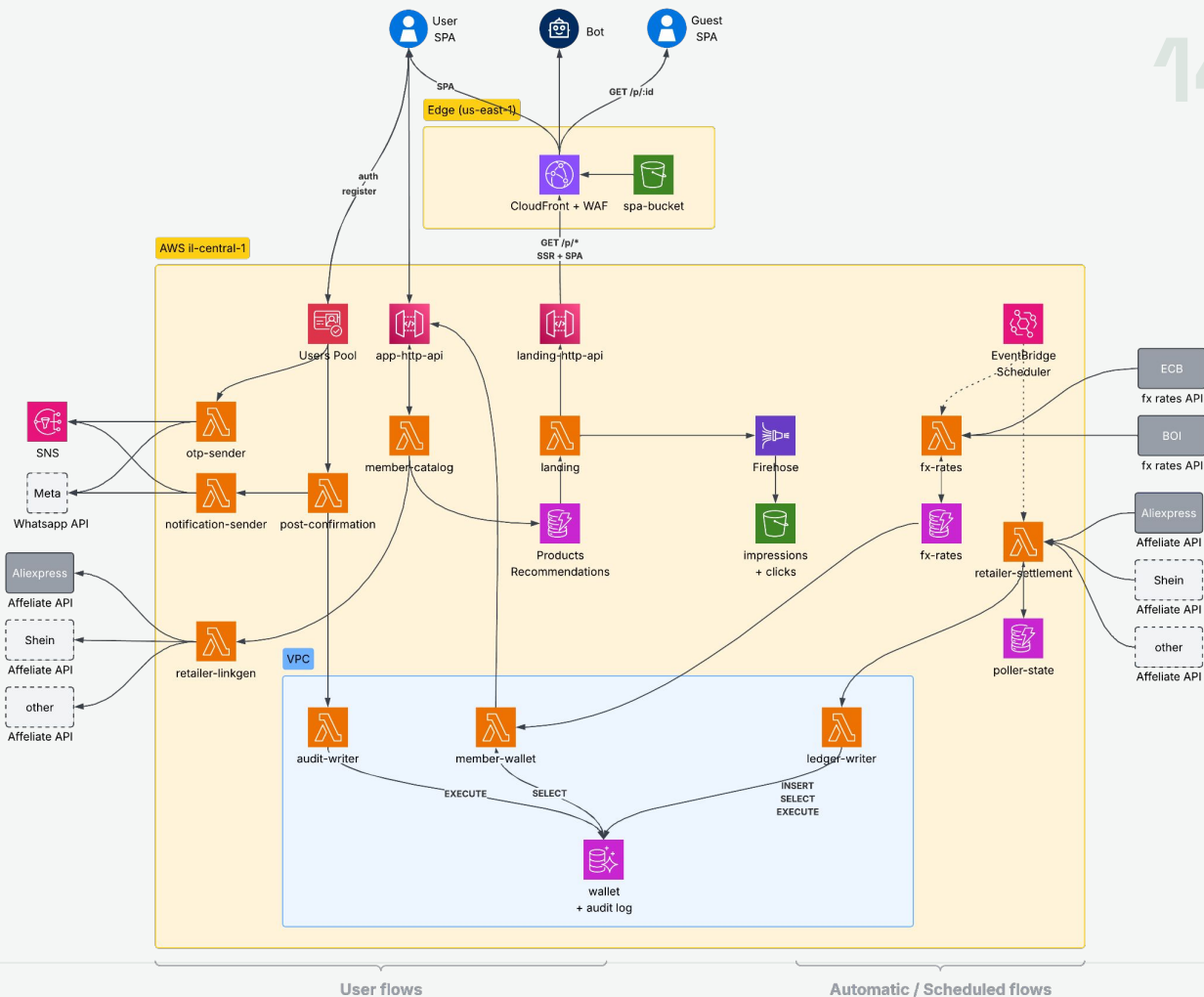


# Architecture

## Usecase 5: User's home page



- Aurora cold start may affect the wallet total and recent activity to be displayed with delay.
- The rest of the features are operational immediately.



The screenshot shows a web application dashboard for 'myfirstproject'. The left sidebar contains a 'Dashboard' link (highlighted in green) and other options like 'Users', 'Status', 'Activity', 'Logins', and 'Configuration'. The main content area is titled 'Dashboard' and includes a subtitle 'Current project statistics across the platform'. It features several summary cards for 'Registered users', 'Active members', 'Online users', 'Products', 'Estimated revenue', 'Pending payments', 'Transactions', and 'Refund amount'. Below these is a 'Latest items' section with a table of users.

| Registered users | Active members | Online users | Products |
|------------------|----------------|--------------|----------|
| 2                | 1              | 3            | 3        |
| + Add            | + Add          | + Add        | + Add    |

| Estimated revenue | Pending payments | Transactions | Refund amount |
|-------------------|------------------|--------------|---------------|
| ₹0.00             | ₹2,46            | ₹0.00        | ₹0.00         |
| + Add             | + Add            | + Add        | + Add         |

Latest items: [Add 1st version](#) · [Add pending](#)

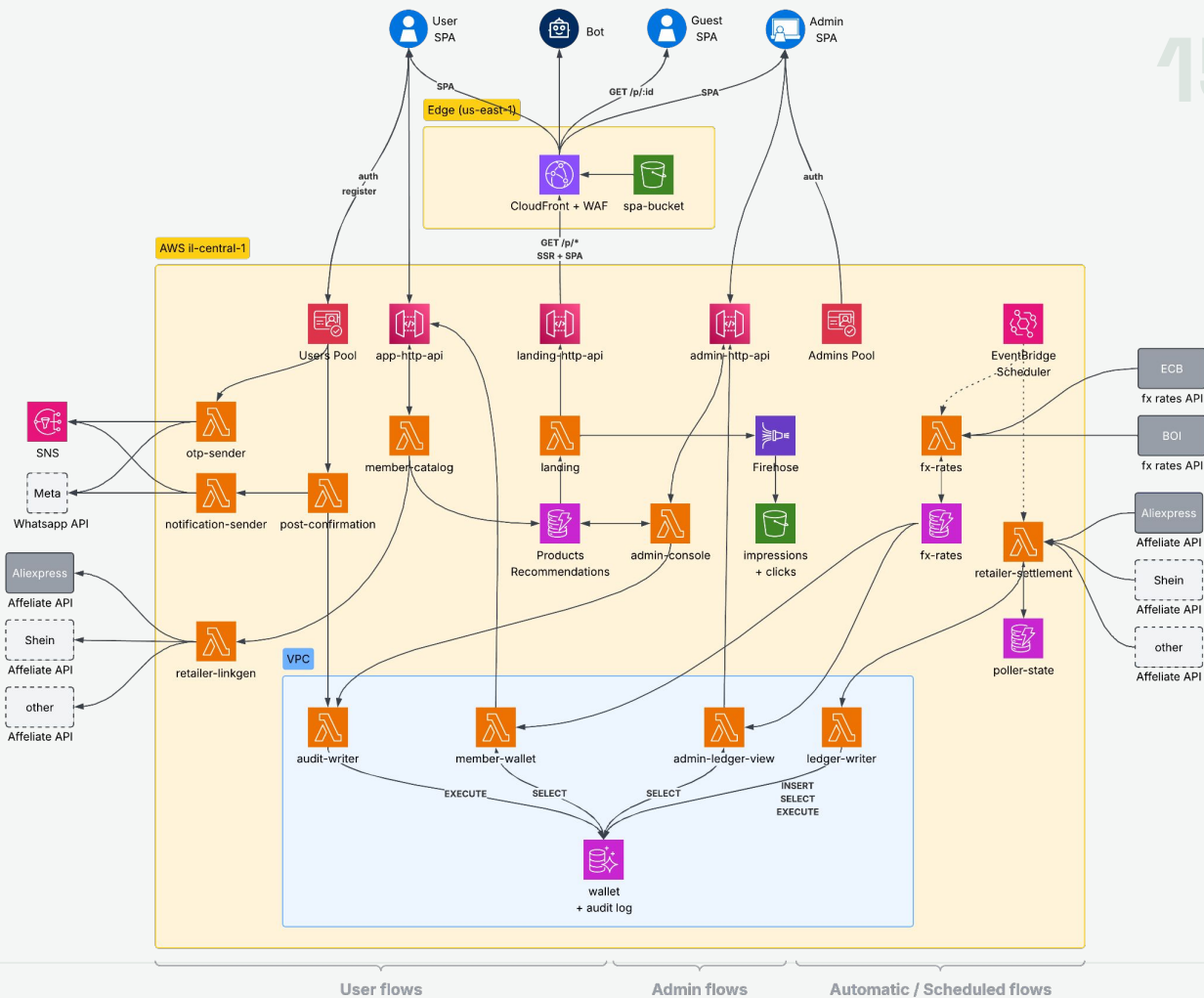
### Users

| 0        | 1        | 1        | 1        | 1        | 0       |
|----------|----------|----------|----------|----------|---------|
| no files | file 123 | file 234 | file 123 | file 234 | unknown |

Registered (0 of 100)

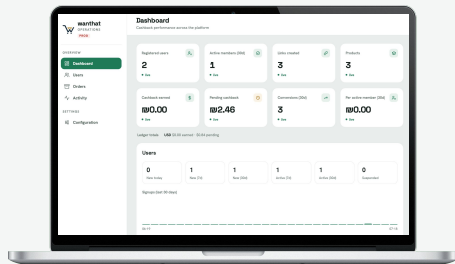
2020-01-01 12:34:56

- Cognito managed login authentication
- Separate users pool on Cognito
- Manipulation of operational data
- Read-only money transactions

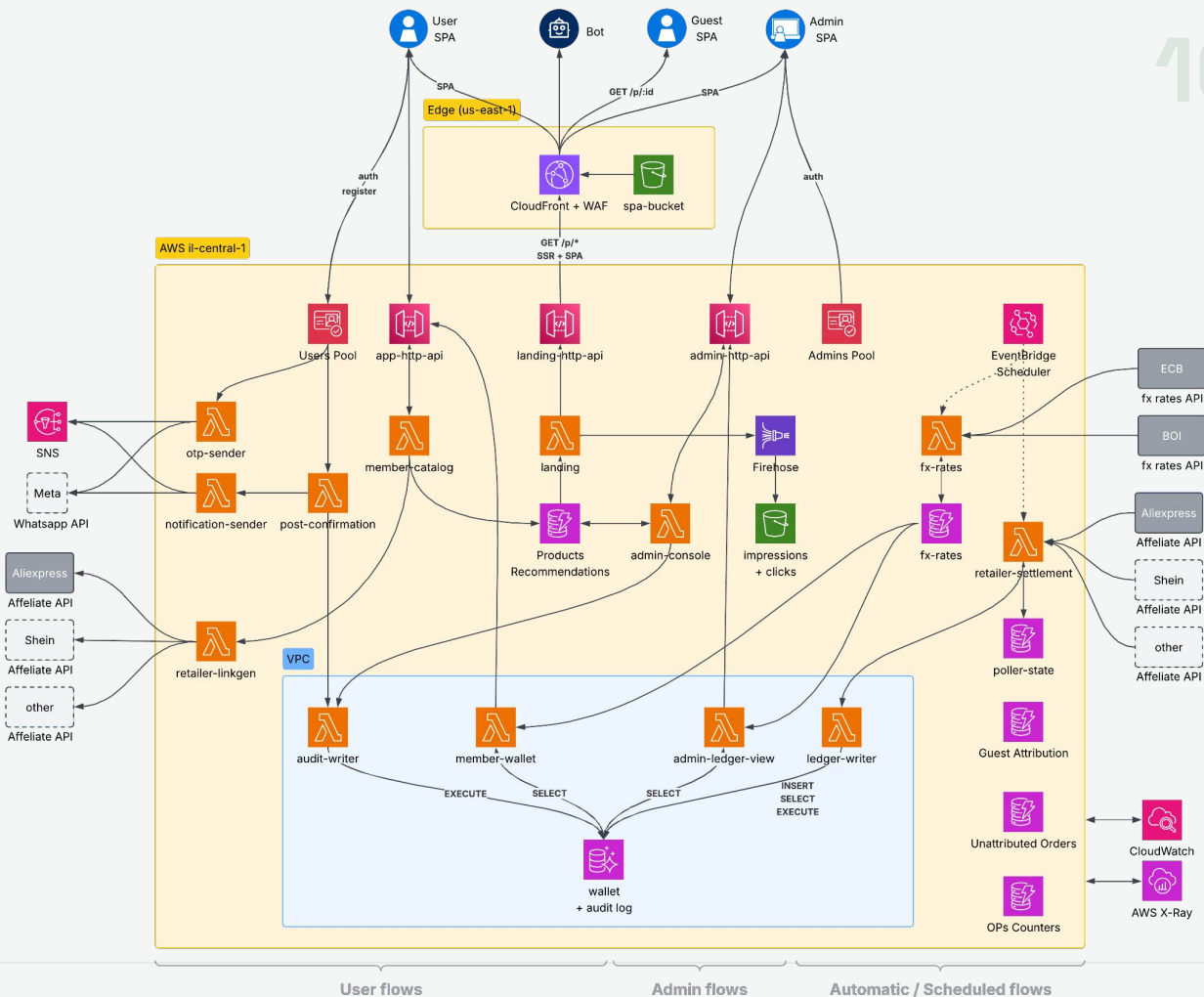


# Architecture

Additional usecases are following the same design principles



- Observability
- Guest attribution within affiliation period
- Manual attribution of unattributed retailer settlements.
- OPs counters for admin real time statistics
- Offline analytics



## Cost model — a measured floor, then linear

| Line item                      | Monthly    | Note                                                                                            |
|--------------------------------|------------|-------------------------------------------------------------------------------------------------|
| Compute + APIs + DynamoDB idle | \$0        | Everything scales from zero; Aurora paused = storage only (~\$2)                                |
| WAF (2 web ACLs + rules)       | ~\$15      | The deliberate fixed floor: CloudFront ACL + Cognito-pool ACL                                   |
| Secrets, Route 53, misc        | ~\$2       | 2 retailer secrets, hosted zone                                                                 |
| OTP delivery                   | capped \$1 | SNS hard cap (SMS sandbox); WhatsApp ~10x cheaper per message at scale — hence WhatsApp-default |
| NAT / proxies / endpoints      | \$0        | Architecturally eliminated (backup B2)                                                          |

**Costs accepted knowingly:** cold-resume UX risk on first wallet read (mitigated by warm-up probe); one AWS account for dev+prod shares SMS caps and quotas — flagged for split.

**Unit economics guardrail:** the redirect hot path costs micro-cents per thousand clicks and cannot touch Aurora — cost scales with revenue-bearing traffic, not with virality.

**Scale projection (10 → 100k users):** next slide.

# Cost projection by user count

| Monthly (prod)                       | 10           | 100          | 1,000        | 10,000        | 100,000         |
|--------------------------------------|--------------|--------------|--------------|---------------|-----------------|
| WAF (2 ACLs, fixed + \$0.60/M req)   | \$14         | \$14         | \$14         | \$15          | \$27            |
| API Gateway (~\$1.2/M)               | ~\$0         | ~\$0         | \$0.40       | \$4           | \$36            |
| Lambda (256MB arm64)                 | ~\$0         | ~\$0         | \$0.20       | \$2           | \$18            |
| DynamoDB on-demand                   | ~\$0         | ~\$0         | \$0.40       | \$4           | \$40            |
| Aurora (compute + storage)           | ~\$3         | ~\$8         | ~\$45        | ~\$80         | ~\$220          |
| RDS Proxy (8-ACU minimum)            | —            | —            | —            | ~\$100        | ~\$100          |
| Cognito (\$0.015/MAU after 10k free) | \$0          | \$0          | \$0          | \$0           | \$1,350         |
| CloudFront + misc                    | ~\$3         | ~\$3         | ~\$5         | ~\$12         | ~\$42           |
| <b>Total</b>                         | <b>~\$20</b> | <b>~\$25</b> | <b>~\$65</b> | <b>~\$215</b> | <b>~\$1,835</b> |

Assumptions: 10 operations/user/day, ~70/30 read-write, il-central-1 approximate prices, prod only; every active user = 1 Cognito MAU; RDS Proxy included from 10k users. Two step functions, then linear: Aurora stops sleeping (~1k users); the Cognito free tier ends at exactly 10k MAU. Per-user at 100k: ~\$0.018/month.

## Known limits — and their revisit triggers

| Limitation                         | Current stance                                    | Revisit trigger                                        |
|------------------------------------|---------------------------------------------------|--------------------------------------------------------|
| Single active region               | Cross-region backups only; RTO = hours (ADR-0005) | Revenue SLA or user base that prices an active-standby |
| Cognito PII: no PITR, weak queries | Accepted for MVP; profile is thin                 | Compliance/BI needs → dual-write projection to SQL     |
| Account concurrency = 10           | No reserved concurrency anywhere (deliberate)     | Quota raise, then per-function caps return             |
| dev + prod in one account          | Shared SMS cap and service quotas                 | Before marketing push: account split                   |
| Retailer throttling interim        | Sequential + one ban-window retry (ADR-0021)      | Poller volume growth or AliExpress app approval        |

## Questions?

backup: sequence diagrams · failure modes · the rejected-alternatives list

Q&A MATERIAL

# Backup

Decisions and trade-offs · sequence diagrams · schemas · operations · the ADR map

# Auth — three options

## A Cognito Managed Login

Hosted pages, PKCE — zero auth code to own

REJECTED: no Hebrew/RTL (12 locales, text not editable); passkey RP-ID forced to the auth subdomain — credentials siloed off wanthat.app.

## B Cognito-native, own UI

Browser calls SignUp / InitiateAuth / WEB\_AUTHN directly; profile = ID-token claims

CHOSEN: zero backend calls to authenticate; full RTL UI; pool WAF + quotas as abuse control.

## C App-owned ceremonies

Proxy every OTP step, own WebAuthn store, Ed25519 ticket bridge, AdminSetUserPassword exchange

ALTERNATIVE — NOT PURSUED: 2 Lambdas + 3 tables + a crypto path buy exactly ONE feature — useless Face ID; the requirement was waived, so that cost buys nothing.

**Trade-offs signed off with B:** useless Face ID waived (remembered-phone one-prompt kept); phone enumeration accepted (preventUserExistenceErrors LEGACY) — mitigated by pool WAF rate rules; JWT revocation lags up to 15 min on our APIs (stateless authorizer, 15-minute access tokens) — acceptable for the current member surface.

**Measured effect:** login requires zero backend calls; the Aurora cold-resume login stall (~20 s) is structurally impossible.

## Network — pay for nothing that idles

| Component avoided        | Fixed cost avoided    | Replaced by                                                                                                 |
|--------------------------|-----------------------|-------------------------------------------------------------------------------------------------------------|
| NAT Gateway              | ~\$33/mo + \$0.045/GB | Non-VPC functions call public AWS endpoints (IAM + TLS); the only true internet egress is the retailer tier |
| VPC interface endpoints  | ~\$7-15/mo each       | Zero needed: nothing in-VPC calls Cognito, Secrets Manager, or the internet — by design, not by exception   |
| RDS Proxy                | per-ACU hourly        | Direct IAM DB auth; 50-connection cap + no reserved concurrency keeps pressure bounded                      |
| DynamoDB access from VPC | —                     | Free gateway endpoint                                                                                       |

**Structural consequence:** in-VPC functions cannot initiate outward calls — the conversion chain is always proxy → writer (invoke), and admin claim intents settle asynchronously on the next poll heartbeat.

**Blast-radius bonus:** the retailer credential is readable by exactly one non-VPC function; a compromised in-VPC function has no path to it or to the internet.

**Revisit trigger:** sustained Aurora connection pressure (alarm at 80% of 50) → RDS Proxy; steady traffic → reserved concurrency once the account quota (10) is raised.

# Money — poll over webhook, append over update

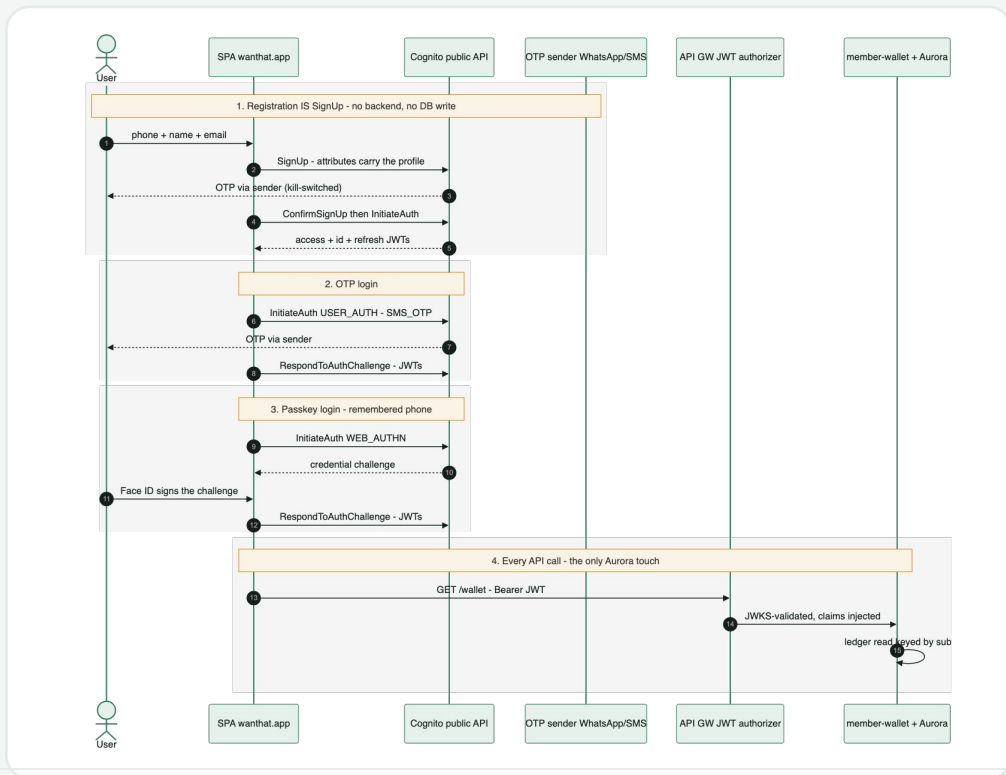
## Ingestion: scheduled reconciliation

- Webhooks rejected: an inbound money-bearing endpoint is a spoofing surface, needs ordering and retry semantics, and the retailer offers no reliable one anyway (ADR-0009).
- Poll = a cursor in poller\_state + listOrdersByIndex every 30 min: replayable from any point, idempotent by the ledger unique index, nothing to authenticate inbound.
- Accepted latency: minutes to surface, 24-48 h to confirm (retailer settlement dominates — the product promise is days, not seconds).
- Interim throttling (ADR-0021): sequential calls + one ban-window retry; revisit at volume.

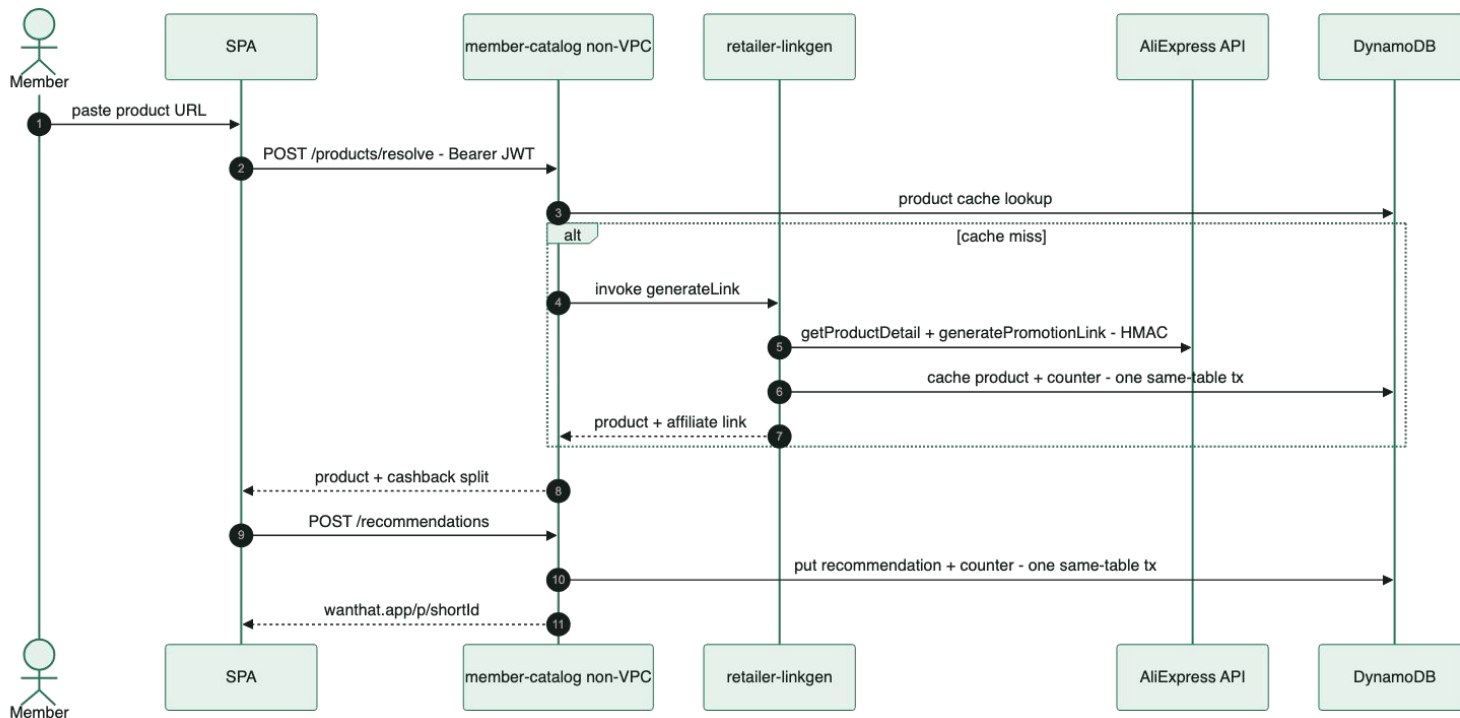
## Storage: append-only + GRANT-enforced

- Lifecycle is data, not mutation: pending → confirmed → clawback are separate immutable rows; balances are always derived.
- The invariant lives in Postgres, not app code: UPDATE/DELETE revoked from every role; only ledger\_writer can INSERT; audit\_append is SECURITY DEFINER and the only door into the audit log.
- Hash-chained audit log makes tampering evident; admin config changes audit the same way.
- Blast radius: a bug or compromise in any read path has zero write capability on money.

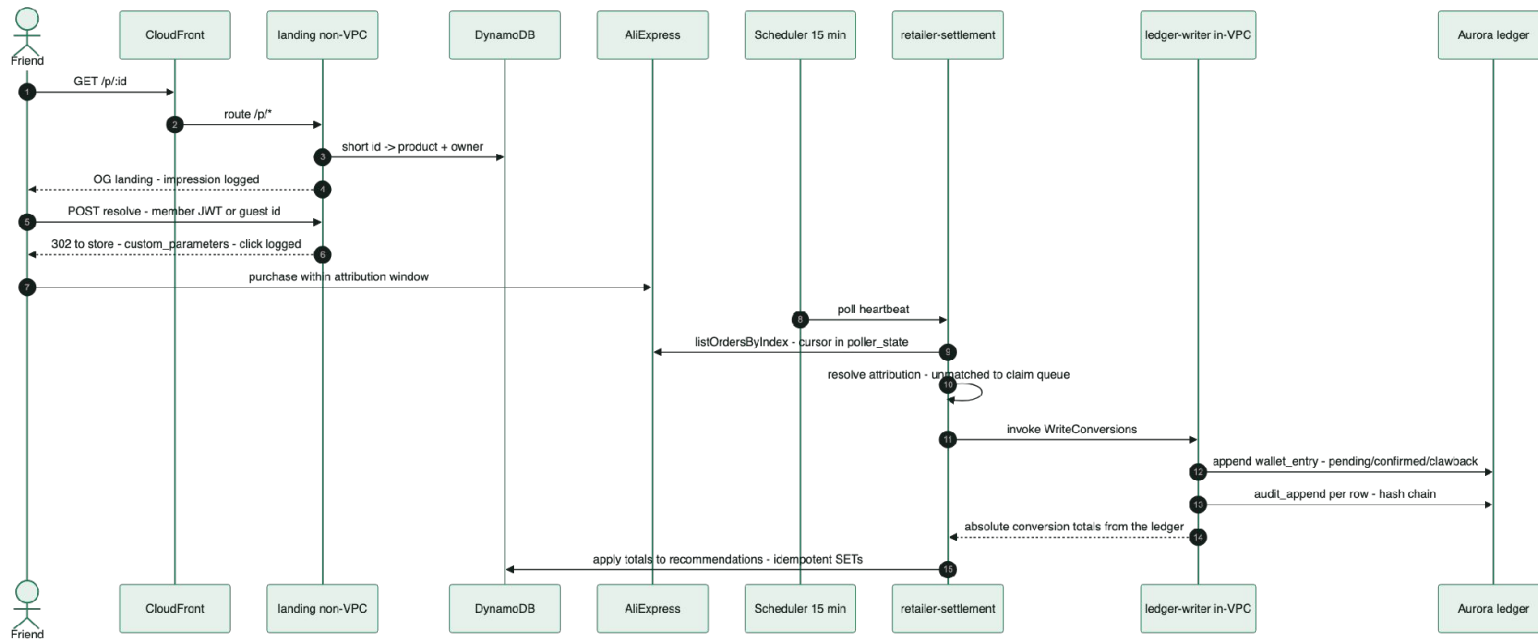
# Sequence — customer auth, all four flows



## Sequence — create a link



# Sequence — click to ledger



## Trade-off — HA vs single region (ADR-0005)

### Chosen: single active region

- Target: 99.5% availability (~3.6 h/month) — lenient by design for an MVP.
- il-central-1 active; eu-central-1 is a RESTORE target, not a standby.
- RPO ~minutes (PITR); RTO ~hours (region-loss rebuild from cross-region copies).
- Hard constraint: Cognito has NO multi-region replication in il-central-1 — hot identity failover is not natively possible at any spend.

### Rejected, and when to revisit

- Active-passive multi-region now: not required for 99.5%; identity failover would be non-native anyway; unjustified cost + complexity at MVP.
- In-region backups only: a region incident would lose a money ledger — unacceptable at any SLA.
- Revisit: an SLA beyond 99.5%, or identity region-loss recovery becoming a hard requirement.

## Backup strategy (ADR-0005)

| Data                         | In-region                       | Cross-region (eu-central-1)                                   |
|------------------------------|---------------------------------|---------------------------------------------------------------|
| Aurora ledger + audit        | PITR, continuous — RPO ~minutes | Automated-snapshot copy                                       |
| DynamoDB (9 tables)          | PITR on every table             | Export / copy for the redirect projection + attribution map   |
| Funnel + audit events (S3)   | Versioning                      | Cross-region replication                                      |
| Secrets                      | —                               | Secrets Manager replication                                   |
| Cognito (identity + ALL PII) | Managed by the pool             | NONE — no cross-region recovery in MVP (accepted, documented) |

The hash-chained audit log complements backups: restores are tamper-evident, not just recoverable.

Status honesty: PITR is live everywhere; the cross-region copy jobs are the one deferred item of ADR-0005 — tracked, not yet deployed.

# Observability

## See

Per-surface CloudWatch dashboards: API count / 5xx / p95, Lambda errors / throttles / p95, Aurora ACU + connections, SMS spend. Edge dashboard (CloudFront + WAF) in us-east-1.

X-Ray tracing on every function; structured logs with retention bounds — dev 1 month, prod 6 months.

## Alert

SNS → ops email: per-Lambda errors (13 steady-state functions), per-API 5xx, Aurora connections at 80% of the 50 cap, month-to-date SMS spend at 80% of the cap.

The two deploy-time triggers are excluded BY DESIGN — their failure fails the deploy itself.

## Analyze

Funnel pipeline: CloudWatch Logs subscription filters on landing / retailer-settlement / ledger-writer pick impression, click, conversion, order\_untracked.

→ Firehose → date-partitioned S3 → Glue → Athena with partition projection.

The alarm list is deliberately short — every alarm is actionable; funnel events are business analytics, not ops noise, which is why they leave CloudWatch.

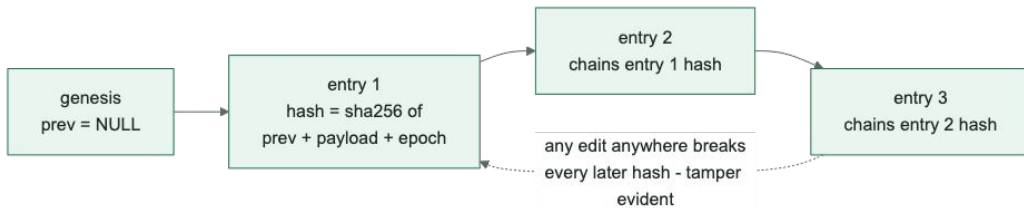
# Aurora schema + the hash chain — conceptual

## wallet\_entry — the append-only ledger

- id, cognito\_sub, kind, amount\_minor, currency, order\_id, recommendation\_id, status, created\_at — no FK anywhere (the user store is Cognito).
- Lifecycle is rows, not updates: pending → confirmed → clawback are separate immutable appends; balances are always derived.
- Unique (order\_id, kind, status) = poll idempotency; UPDATE / DELETE revoked from every role.
- Every append commits with its audit\_append witness in ONE transaction (2026-07-18) — no ledger row can exist unwitnessed.

## audit\_log — hash-chained events

- id, prev\_hash, entry\_hash, payload jsonb, created\_at.
- SECURITY DEFINER audit\_append is the ONLY door in — an advisory lock serializes writers so the chain can never fork.
- entry\_hash = sha256(prev\_hash | payload | epoch(created\_at)) — any edit anywhere breaks every later hash.



## DynamoDB schemas + GSIs

| Table              | Keys                     | GSI / extras                               | Purpose                                      |
|--------------------|--------------------------|--------------------------------------------|----------------------------------------------|
| product            | storeId + storeProductId | counter row in-table                       | retailer product cache (linkgen sole writer) |
| recommendation     | recommendationId         | byOwner (ownerId, createdAt) + counter row | short-link projection + per-link stats       |
| guest_attribution  | guestId                  | —                                          | guest → member carry-over at signup          |
| poller_state       | stateKey                 | —                                          | order-poll cursor                            |
| unattributed_order | orderId                  | byState (state, firstSeenAt)               | admin claim queue                            |
| runtime_config     | configKey                | —                                          | kill switches (admin-console sole writer)    |
| ops_counters       | counterKey               | —                                          | exact counters + daily stats                 |
| fx_rate            | pair (USD#ILS)           | —                                          | FX display-estimate cache                    |
| otp_sink           | phone                    | TTL 5 min                                  | parked OTP codes (admin view)                |

All on-demand + PITR. Exact counters: the #counter sentinel row lives INSIDE the counted table — create/delete + ADD itemCount ride ONE same-table TransactWriteItems (sparse: no ownerId, so GSIs exclude it).

No cross-table transaction exists anywhere — cross-entity consistency is keys + idempotent writes, by design.

# ADR map — locked: supersede, never edit



## Architecture · 0001-0009

0001 monorepo + Zod contracts  
0002 compute seams  
0003 polyglot data, no RDS Proxy  
0004 NAT-free network  
0005 single region + backups  
0006 Cognito-native auth + PII  
0007 landing path + latency  
0008 attribution: custom\_parameters  
0009 poller, not webhook



## Stack · 0010-0016

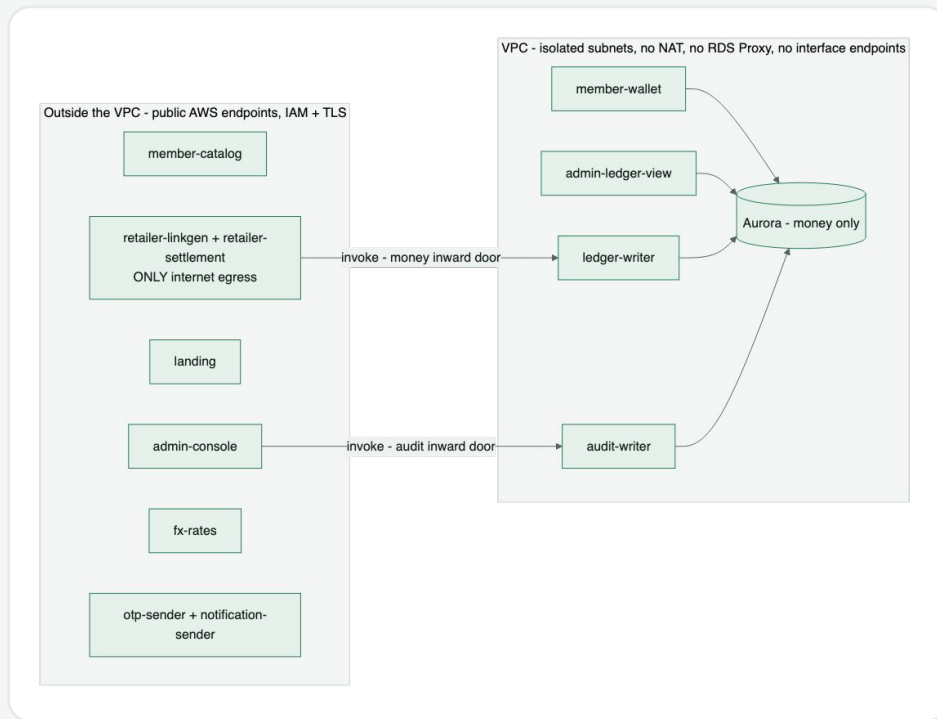
0010 ESM / Node 24  
0011 Hono + Powertools  
0012 Kysely + SQL migrations  
0013 Vitest + Testcontainers  
0014 Biome  
0015 GitHub Actions OIDC  
0016 Vite SPA



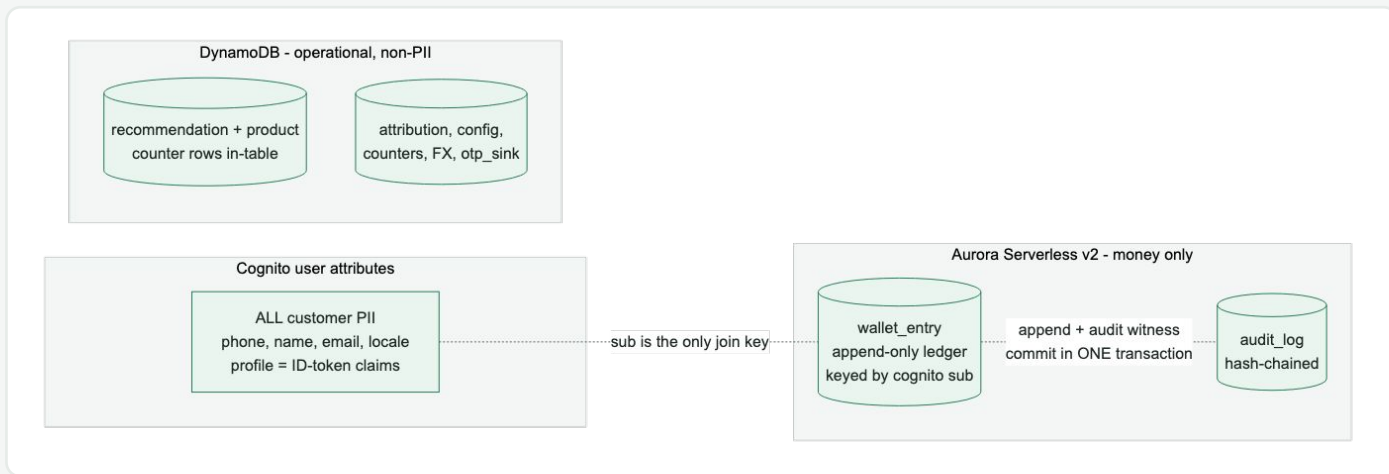
## Extensions · 0017-0021

0017 currency + FX  
0018 CloudFront front door  
0019 WhatsApp messaging  
0020 sub = canonical id  
0021 retailer throttling (interim)

# ADR-0002 + 0004 — compute seams and the NAT-free bet



## ADR-0003 + 0006 — where data lives



- The customer table was dropped when PII moved to Cognito (migration 0006\_money\_only) — the ledger is keyed by the Cognito sub directly.
- Admin user search runs on ListUsers (one-attribute filters); fine at MVP scale — dual-write projection is the escape hatch.
- Trade-offs accepted: no SQL over PII, no PITR for the user pool, attribute changes have no built-in history.

# Failure modes and recovery

| Failure                            | Behavior                            | Recovery                                                                                                    |
|------------------------------------|-------------------------------------|-------------------------------------------------------------------------------------------------------------|
| Aurora cold resume (~20 s)         | First wallet read after idle stalls | SPA fires /healthz/db warm-up probe on auth screens; 60 s connect timeout rides it out                      |
| AliExpress ApiCallLimit ban window | Poll heartbeat calls rejected       | Sequential calls + one ban-window retry (ADR-0021); cursor unmoved → next beat replays                      |
| WhatsApp delivery down             | OTP channel unavailable             | Sticky-preference fallback to SMS; runtime-config kill switches; SNS spend cap bounds abuse                 |
| Settlement poll crash mid-batch    | Partial writes                      | Cursor advances only after batch; ledger unique index + absolute stat SETs make replays no-ops              |
| Notification invoke keeps failing  | Welcome message undelivered         | Lambda async retry x2 → real-payload SQS DLQ (redrivable); kill-switched skips return success and never DLQ |
| Cognito outage                     | No new logins                       | Static SPA still serves; landing redirect works for guests (DynamoDB-only path)                             |

## Rejected alternatives — the graveyard

| Alternative                        | Why not                                                                                                         |
|------------------------------------|-----------------------------------------------------------------------------------------------------------------|
| RDS Data API (no-VPC SQL)          | Not available in il-central-1 — verified, killed the design branch                                              |
| Lambda Function URLs for landing   | Not available in il-central-1 → HTTP API behind CloudFront /p/*                                                 |
| NAT + interface endpoints          | Fixed monthly cost for idle capability; non-VPC chaining is \$0 and least-privilege by construction             |
| RDS Proxy                          | Cost + unneeded at 50-connection scale; revisit on connection-pressure alarm                                    |
| Managed Login for customers        | No Hebrew/RTL; passkey RP-ID silo on the auth subdomain (kept for the admin console, where it fits)             |
| Conversion webhooks                | Spoofable inbound money surface + no reliable retailer support; reconciliation poll is replayable and auditable |
| Self-minted session JWTs           | A second token validation path across every API; Cognito stays the only issuer                                  |
| Aurora customer table (PII in SQL) | Kept Aurora on the auth path and PII in two stores; moved to Cognito attributes (ADR-0006)                      |